

SECURITY INCIDENT REPORT

Incident Date: 03 July 2025

Incident Timeframe: 04:00 – 09:15

Detection Source: SIEM Alert

Reporting Analyst: Deborah Adekanye

1. Incident Description

On 3rd July 2025, between 04:00 and 09:15, the SIEM generated multiple malware detection alerts. Investigation revealed 16 login attempts targeting the same user accounts from different IP addresses. Of these attempts, 11 were successful, resulting in several user accounts being compromised.

Following the successful logins, the attacker accessed multiple files, which triggered the malware detection alerts. Five malware types were identified namely:

- Rootkit
- Ransomware
- Trojan
- Worm Infection
- Spyware

The **Compromised user accounts** belonged to Bob, Eve, David, Charlie, and Alice.

2. Impact Analysis

The impact of the malware types was analysed under the technical and business categories and grouped by severity.

Categories/Severity	Critical	High	Medium
Technical Impact	•Rootkit: Can allow attackers operate stealthily, thereby undermining system integrity. It can also enable further malware installation and compromise security monitoring. •Ransomware: Causes operational disruption, as critical	•Trojan: Being the initial infection vector, it enables attackers to deploy further malware such as ransomware or rootkits. Credential theft is also facilitated through Trojans. •Worm Infection: Self-replicates and spreads rapidly across systems, causing	•Spyware: Focuses on covert data collection, such as capturing credentials or sensitive information, leading to loss of confidentiality. It is not immediately disruptive.

	business files and systems are encrypted and unusable. It also poses a risk to data integrity if data is tampered with, and to data security, where sensitive data is stolen.	decreased network performance. It can also introduce other malware, enable unauthorized access to data, data modification or loss.	
Business Impact		•Data Compromise: Spyware, Trojans, and rootkits may expose sensitive information, including credentials, internal documents, and customer data, increasing regulatory and legal risk. •Regulatory & Compliance Risk: Depending on the nature of the accessed data, the organisation may face GDPR or other compliance obligations, including breach notifications and potential fines. •Reputational Damage: A multi-malware incident involving account compromise and unauthorised access can erode customer trust and damage the organisation's public image.	•Financial Loss: Costs may arise from downtime, system restoration, loss of revenue, incident response and potential ransom demands. •Operational Disruption: Ransomware and worm activity can halt or slow down business operations, affecting productivity and delaying service delivery.

3. Immediate Remediation Actions

Ransomware

- Isolate infected systems and wipe compromised machines.
- Rebuild the system if the integrity is uncertain.
- Restore files from clean, verified backups.

Rootkit

- Isolate the compromised device.
- Scan device offline using rootkit detection tools such as RootkitRevealer or boot from a trusted medium.
- Execute rootkit-specific cleaners to remove any malicious software.
- Re-install Operating System to ensure full removal.
- Reset all associated credentials.

Trojan

- Quarantine the malicious file using EDR or antivirus tools.
- Remove persistence mechanisms such as registry keys or scheduled tasks.
- Reset passwords for all affected users.

Worm Infection

- Segment the network to prevent further spread.
- Block malicious ports or protocols.
- Patch exploited vulnerability.
- Clean infected systems using EDR or antivirus tools
- Monitor the environment closely for reinfection attempts.

Spyware

- Perform a full system scan to identify and remove spyware.
- Delete any malicious extensions or applications.
- Block outbound connections to suspicious domains.
- Reset credentials for all affected users.

4. Recommendations for Future Prevention

The following recommendations are made to prevent future recurrence of the identified malware types:

Ransomware

- Maintain immutable or offline backups to ensure data can be restored safely.
- Strengthen password policies with mandatory MFA in place.
- Regularly patch vulnerabilities that ransomware actors commonly exploit.

Rootkit

- Enable Secure Boot and firmware integrity checks to prevent low-level tampering.
- Operating systems and drivers must be kept fully patched.
- Restrict administrative privileges to enforce least-privilege access.

Trojan

- Enhance email filtering and attachment scanning to reduce the risk of malicious downloads.

- Enforce application allow-listing to limit unauthorised software execution.
- Install reliable antivirus software.
- Conduct regular training and awareness on phishing and social engineering.
- Promptly patch all software vulnerable to Trojan exploitation.

Worm Infection

- Implement Network Access Control to restrict unauthorised device connections.
- Deploy Intrusion Prevention Systems (IPS) to block worm-like behaviour.
- Strengthen patch management to close exploitable vulnerabilities.
- Disable all unnecessary services to reduce the attack surface.

Spyware

- Enforce browser hardening to limit exposure to malicious scripts.
- DNS filtering should be used to block access to harmful domains.
- Keep Operating systems and browsers fully patched.
- Educate users on avoiding suspicious downloads and pop-ups.

5. Conclusion

The incident has been successfully contained, with all compromised accounts and systems remediated. Enhanced monitoring has been implemented to ensure continued visibility across the environment, and a set of strategic preventive recommendations has been provided to strengthen long-term security. This security incident report should be reviewed quarterly for continuous improvement in maintaining a resilient security posture.